

COMPLIANCE & SECURITY · CHECKLIST

Minimum Viable Security Posture Checklist

For founders and operators who need a credible, defensible security baseline without building an enterprise security program.

How to use this: Work through each domain and check off what's genuinely in place today; anything unchecked is your near-term action list.

Trust and Transparency

- ☐ We have a plain-language statement of how we protect customer data that we can share on request.
- ☐ We know which of our subprocessors or vendors touch customer data, and could list them if asked.
- ☐ We have a named person (even part-time) who owns security-related questions from customers.
- ☐ We have a basic privacy policy and terms of service that accurately reflect what we actually do.
- ☐ We could answer 'how is our data protected' in under five minutes, in writing, today.

Access Control

- ☐ We can list everyone with access to production systems and why they have it.
- ☐ We can list everyone with access to customer data and why they have it.
- ☐ Access to billing, admin, and infrastructure systems uses individual logins, not shared credentials.
- ☐ Multi-factor authentication is enabled on email, code repositories, cloud infrastructure, and billing systems.
- ☐ We have a process for removing access within 24 hours of someone leaving or changing roles.

Device and Endpoint Basics

- ☐ All company laptops and phones used for work are password-protected and encrypted.
- ☐ Lost or stolen devices can be remotely locked or wiped.
- ☐ Company data isn't routinely stored only on personal, unmanaged devices.
- ☐ Software and operating systems on work devices are kept on a current, supported version.

Documentation and Process

If the founder or lead engineer disappeared tomorrow, could someone else answer these from documentation alone?

Where is our current list of who has access to what, and when was it last updated?

Where is our written process for onboarding and offboarding access?

Where is our written process for what happens if we suspect a security incident?

Who is the single point of contact for a customer's security or procurement question?

Baseline Status Summary

Domain	Current State (Strong / Partial / Missing)	Owner	Next Action
Trust & Transparency			
Access Control			
Devices & Endpoints			
Documentation & Process			